

Clase 2

Hardening en S.O

- Servicios y procesos
 - Desactivar servicios no utilizados
 - Revisar procesos en ejecucion y puertos abiertos
- Gestion de cuentas y accesos
 - Deshabilitar cuentas innecesarias
 - Uso de contraseñas robustas y MFA
 - Principio de minimo privilegio (PoLP)
- Aplicar parches y actualizaciones de seguridad
- Configurar firewalls locales
- Activar logs y auditoria, backups seguros
- Endpoint detection and Response y cifrado de discos
 - OpenEDR: ofrece telemetria avanzada, deteccion en tiempo real y visibilidad MITRE
 - ATT&CKMITRE ATT&CK es uan base conocimiento de acceso global sobre tacticas y tecnicas adversarias basadas en observaciones del mundo

Hardening de Redes

- Segmentación de red con VLANs y firewalls internos
 - Sniffing AI
 - Barrido de puertos
 - Ataques de protocolos
- Autenticacion fuerte
 - MFA
 - Control de accesos basado en roles
- Deshabilitar servicios / protocolos inseguros (TELNET)
- Monitoreo constante con IDS/IPS y SIEM
 - Patrones de trafico
- Gestion de parches y firmware actualizados
- Backups y pruebas periodicas de vulnerabilidades

VPN Tradicional vs Zero Trust

Zero Trust vs Segmentación clásica con VPN

Aspecto	Segmentación clásica con VPN	Zero Trust
Modelo de confianza	Confianza en lo interno (perímetro fuerte, interior débil)	Nunca confiar, siempre verificar cada acceso
Acceso a recursos	Acceso amplio a la red al conectarse	Acceso granular solo al recurso autorizado
Autenticación	Usuario + contraseña al iniciar sesión	Autenticación continua, MFA, validación contextual
Segmentación	VLANs y firewalls internos	Microsegmentación dinámica basada en identidades y políticas
Escalabilidad	Complejo y rígido al crecer la red	Flexible: políticas centralizadas en entornos híbridos/cloud
Visibilidad y monitoreo	Limitado, depende de registros en VPN/firewall	Monitoreo continuo del comportamiento y anomalías
Protección ante ataques internos	Débil: movimiento lateral posible dentro de la VPN	Fuerte: control granular reduce superficie de ataque
Entornos modernos (cloud, SaaS, BYOD)	Difícil de adaptar	Diseñado para entornos distribuidos y heterogéneos

Hardening en Aplicaciones y Servicios

- Deshabilitar módulos no usados (ej. En Apache, IIS, MySQL)
- Revisar y limitar permisos de archivos y directorios
- Configura contraseñas seguras y autenticación multifactor (MFA)
- Proteger bases de datos (encriptación, revisar y limitar permisos de archivos y directorios)
- Uso de parámetros seguros en apps web. (TLS, HSTS, Cookies Seguras)

Vulnerabilidades en Infraestructura crítica

Ambito → Energía, agua, transporte, telecomunicaciones, salud, etc

Impacto

- Interrupción de servicios esenciales para la sociedad
- Riesgo de seguridad física para personas
- Consecuencias políticas y económicas a gran escala

Ciberseguridad Operational Technology en Infraestructura Crítica

“Se refiere al conjunto de estrategias, procesos, tecnologías y prácticas de seguridad informática aplicadas a los sistemas de control industrial”

ICS, Sistemas de Control Industrial, SCADA, Sistemas de Supervisión, Control y Adquisición de Datos, DCS, Sistemas de Control Distribuido

PLCs, Controladores Lógicos Programables y otros componentes de la tecnología

operativa

que gestionan servicios esenciales como energía, transporte, agua, telecomunicaciones y salud

- Enfoque en disponibilidad a diferencia de la ciberseguridad TI, donde prima la confidencialidad, en OT/IC la prioridad es mantener la operación continua.
- Superficie de ataque híbrida combina riesgos cibernéticos (ransomware intrusiones) con riesgos físicos (fallas de sistemas de control)
- Otro desafío es integrar la seguridad OT/IC con los sistemas informáticos (IT) como por ejemplo SAP
- P ej Múltiples sistemas SCADA cada uno corriendo una versión distinta según el operador o prestador y según cuando entre en operación

OBJETIVO

garantizar la disponibilidad, integridad y confiabilidad de los procesos físicos y digitales protegiéndolos frente a amenazas cibernéticas que podrían tener consecuencias no solo económicas, sino también sociales, ambientales y de seguridad física para la población

Estandares de Seguridad

Objetivos principales

- Protección de sistemas de control industrial
- Separación de redes IT y OT (defensa en profundidad)
- Monitoreo continuo y detección temprana de anomalías
- Planes de respuesta ante incidentes de alto impacto

Normativas y marcos relevantes

- NIST Cybersecurity Framework (CSF) → Gestión de riesgos de ciberseguridad.

<https://www.nist.gov/cyberframework>

- NERC CIP (Critical Infrastructure Protection) → Estándares para sector eléctrico.

<https://claroty.com/complying-with-the-nerc-cip-standards>

- IEC 62443 → Seguridad para sistemas de automatización industrial y control.

<https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards>

- ISO/IEC 27019 → Seguridad de la información en sistemas de energía.

<https://www.iso.org/standard/85056.html>

- CIS Controls → Buenas prácticas aplicables a ICS/

<https://www.cisecurity.org/controls>

Defensa en profundidad OT/IC

- Gobernanza políticas, capacitación, gestión de proveedores
- Seguridad Física control de accesos, vigilancia, segregación de áreas
- Redes segmentación IT/OT, firewalls, IDS/IPS industriales
- Dispositivos acceso seguro a PLC/RTU/HMI, gestión de parches
- Aplicaciones endurecimiento de SCADA, listas blancas, backups

- Datos cifrado, monitoreo de logs, integridad de procesos
- Resiliencia SOC/CSIRT OT, redundancia, planes de recuperación

Riesgos PLC y SCADA en entornos industriales

- PLC Controladores Lógicos Programables
 - Alteración de lógica de control → interrupción de procesos críticos.
 - Accesos no autorizados → manipulación remota.
 - Malware específico (ej. Stuxnet) que explota vulnerabilidades en firmware.
 - Ausencia de autenticación robusta en muchos dispositivos legacy
- SCADA (Supervisory Control and Data Acquisition)
 - Intercepción de comunicaciones → alteración de datos en tránsito.
 - Secuestro de HMI → visualización falsa de parámetros.
 - Denegación de servicio (DoS) → pérdida de monitoreo y control.
 - Uso de protocolos inseguros (ej. Modbus, DNP3 sin cifrado)

Recomendaciones

- Implementar autenticación y control de acceso a PLC y SCADA
- Monitorear continuamente tráfico OT con IDS/IPS especializados
- Segregar entornos IT/OT mediante firewalls y DMZ industriales
- Aplicar gestión de parches y pruebas en entornos controlados
- Desarrollar planes de respuesta a incidentes con foco OT
- Capacitar al personal en ciberseguridad industrial

Vulnerabilidades en IoT

Ambito: dispositivos inteligentes: camaras IP, wearables, domotica, autos conectados, sensores medicos

- Impacto típico
 - Invasión de la privacidad (ej. cámaras hackeadas).
 - Uso de dispositivos como botnets para ataques DDoS
 - Riesgos en seguridad física (ej. autos conectados, dispositivos médicos).

Seguridad en IoT

- Objetivos principales
 - Autenticación segura y gestión de credenciales.
 - Cifrado de datos en tránsito y en reposo.
 - Actualizaciones seguras de firmware/software.
 - Resiliencia frente a ataques de botnets y DD

Normativas y estándares clave

-

ISO/IEC 30141 → Arquitectura de referencia IoT.2018

<https://www.iso.org/standard/88800.html>

-

ISO/IEC 27400 → Seguridad y privacidad en IoT.2022

<https://www.iso.org/standard/44373.html>

-

NISTIR 8259 → Ciberseguridad para dispositivos IoT . 2020

<https://csrc.nist.gov/pubs/ir/8259/final>

-

ETSI EN 303 645 → Estándar europeo de ciberseguridad en IoT . 2020

https://www.etsi.org/deliver/etsi_en/303600_303699/303645/02.01.01_60/en_303645v020101p.pdf

-

OWASP IoT Top 10 → Principales riesgos en IoT . 2021

<https://owasp.org/www-project-internet-of-things/>

Seguridad en Dispositivos

- Secure Elements AppKey NwkKey Microchip ATECC 608 A TNG(LORA), STSAFE A 110 NXP SE 050
- Firmware seguro MCUboot boot firmado), mbedTLS TinyCrypt TrustedFirmware M (ARMv 8 M
- Prácticas OTAA, LoRaWAN 11 claves únicas, rejoin para rotación, FUOTA con firma

Seguridad en Gateways edge

- Semtech LoRa Basics Station (WebSocket CUPS para provisión y rotación de certificados
- Modelos Kerlink Tektelic MultiTech Laird MikroTik (ver compatibilidad con Basics Station
- Hardening SO actualizado, SSH con claves, iptables ufw mínimo, postura con Wazuh u osquery /Fleet Referencias

Buenas prácticas de clave

- Separar AppSKey (en App Server) de claves de red FNwkSIntKey SNwkSIntKey NwkSEncKey
- Forzar TLS/ mTLS entre gateway LNS/JS App vigilar counters y DevNonce
- Referencias The Things Stack docs HashiCorp Vault / Smallstep step ca